

Authentication Protocol Project
Sanctum based on (OAuth) in Laravel php



Project members :

1- Hana Emad	2206148
2- Marwan Gaber	2206167
3- Omar Ibrahim	2206209
4- Youssef Tamer Mohamed Aly	2206208
5- Mohamed Salah Eldin	22010448
6- Kareem Hossam	22010441
7- Ammar Essam	2206211

Eng. Ahmed Osama

Doctor/Hossam Selim

What is Sanctum Authentication Protocol ??

Laravel Sanctum Authentication (Token-Based):

- ⇒ **Laravel Sanctum** provides a lightweight authentication system for SPAs (single page applications), mobile apps, and simple token-based APIs.
- ⇒ When using **token-based authentication**, Sanctum allows each user to generate one or more **personal access tokens**. These tokens are then used to authenticate API requests by including them in the **Authorization** header as a **Bearer token**.
- ⇒ **Sanctum** stores the tokens in the database and verifies them with each incoming request, ensuring secure access. It supports token abilities (scopes), allowing fine-grained permission control per token.

Let's verify our code to see how sanctum work:

- ⇒ In this system, **Laravel Sanctum** is used to generate and manage **personal access tokens** for API authentication. When a user registers, a verification code is sent to their email.
- ⇒ After verifying their email, the user is issued a **Sanctum token** using the **createToken()** method. This token is returned to the frontend and should be included in future requests as a **Bearer token** in the Authorization header.

- ⇒ This approach ensures secure access to protected routes while maintaining a simple and lightweight authentication system tailored for mobile or single-page applications (SPAs). Sanctum stores the tokens in the **personal_access_tokens** table and automatically checks them on every authenticated request.

Sanctum Authentication Workflow (Project Implementation)

1. User Registration

- The user provides name, email, phone number, and password.
- The system validates input and checks if the email or phone already exists.
- If unverified, the user record is updated or created with ***is_email_verified = false***, and a 6-digit verification code is generated and emailed.

2. Email Verification

- The user submits the verification code sent to their email.
- If valid, the system marks the user as verified (***is_email_verified = true***) and generates a personal access token using:

```
$token = $user->createToken('auth_token')->plainTextToken;
```

- This token is returned to the client and used for authenticated API access.

3. User Login

- The user logs in with their email or phone number and password.
- If credentials are correct and the email is verified:
 - A new Sanctum token is issued and returned to the client.

4. Accessing Protected APIs

- The client includes the token in the Authorization header for every request:

Authorization: Bearer <token>

- Sanctum middleware authenticates the request using the token stored in ***personal_access_tokens***.

Security Considerations

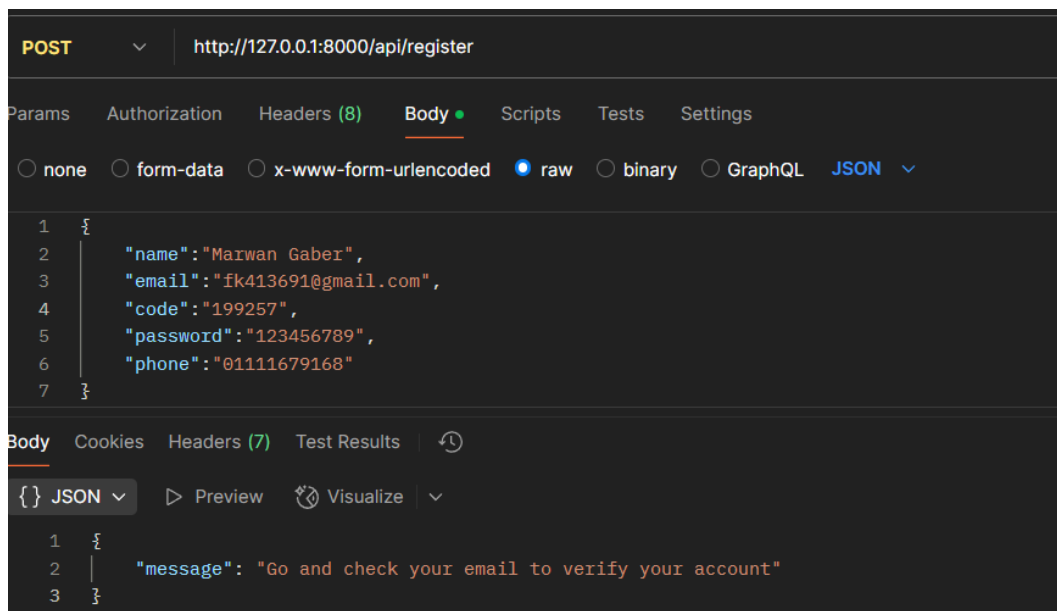
- Tokens are hashed before storage, ensuring they are not exposed even if the database is compromised.
- Each token can have **abilities** (e.g., ['view-profile', 'update-profile']), limiting its access scope.
- Revoking tokens is easy by deleting them from the `personal_access_tokens` table or via model relationships.

Now we will test in postman:

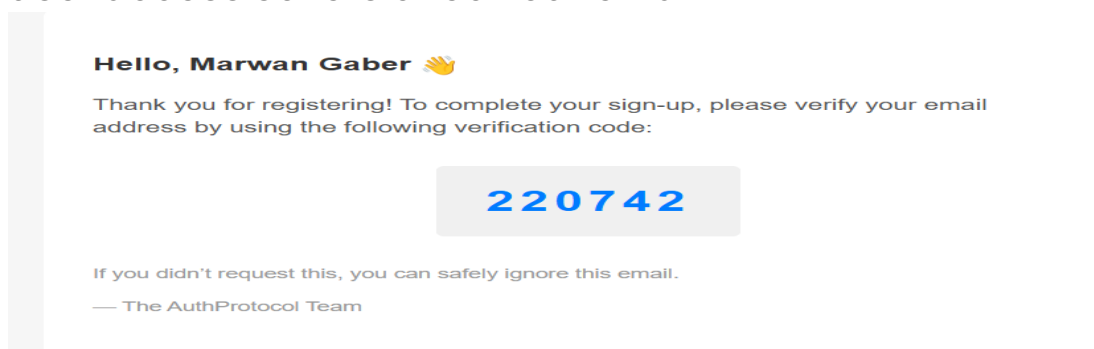
- Now we will test the register end-point in the postman this is the request in the body:

```
- {  
-   "name": "Marwan Gaber",  
-   "email": "fk413691@gmail.com",  
-   "password": "123456789",  
-   "phone": "01111679168"  
- }
```

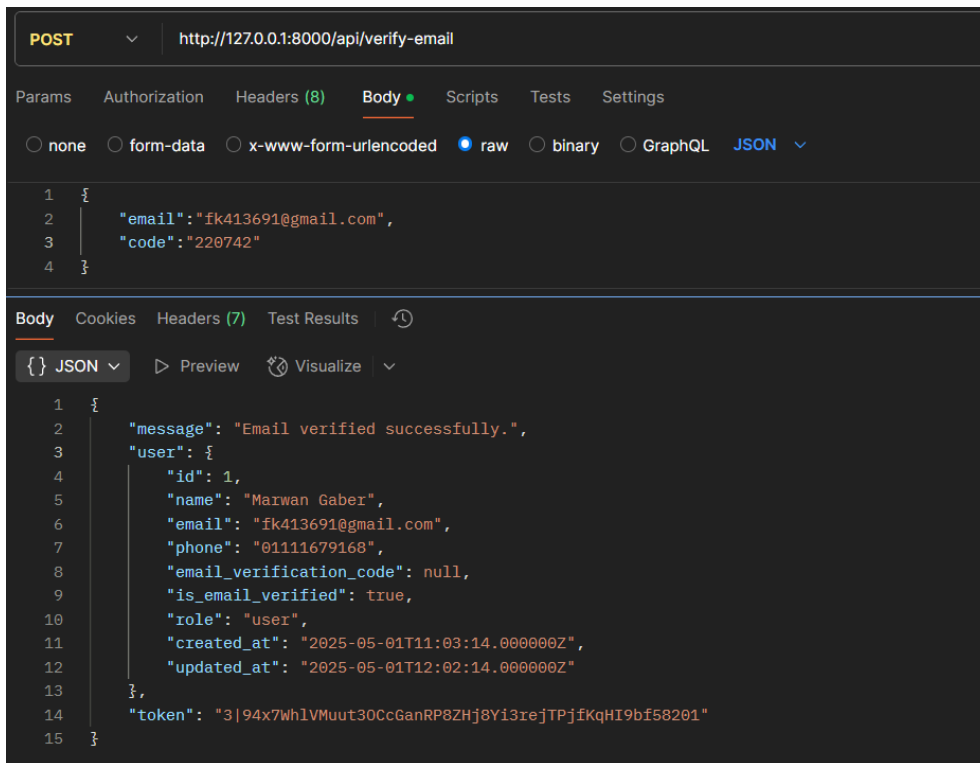
- Lets post it in the postman and this is the screenshot for the request and response :



- We made an over think to authenticate with the email address so when I register an email address comes to me to verify the email and get token to get access for the user access so lets check out email:



- Now let's verify the verification code in Postman and this is another function in code



```
POST http://127.0.0.1:8000/api/verify-email

{
  "email": "fk413691@gmail.com",
  "code": "220742"
}

{
  "message": "Email verified successfully.",
  "user": {
    "id": 1,
    "name": "Marwan Gaber",
    "email": "fk413691@gmail.com",
    "phone": "01111679168",
    "email_verification_code": null,
    "is_email_verified": true,
    "role": "user",
    "created_at": "2025-05-01T11:03:14.000000Z",
    "updated_at": "2025-05-01T12:02:14.000000Z"
  },
  "token": "3|94x7WhlVMuut30CcGanRP8ZHj8Yi3reJTPjfKqHI9bf58201"
}
```

As we see we got token to access the user permissions after verifying the email now this token will be saved for this user in the database for every action to API he has access for

Summary

- ⇒ Laravel Sanctum offers a modern, secure, and scalable token-based authentication protocol that aligns perfectly with the requirements of mobile applications, SPAs, and microservice architectures. It bridges the gap between simplicity and security without the overhead of full OAuth2-based systems.

The link for the project at GitHub :

- ⇒ <https://github.com/Marwan-afk4/AuthProtocol.git>

